

Laporan Insiden 3 — Simulasi Pasca-Eksploitasi (Discovery & Living-off-the-Land)

LAPORAN INSIDEN KEAMANAN — RAHASIA INTERNAL

Dokumen ini merangkum simulasi aktivitas pasca-eksploitasi (post-exploitation) di lingkungan lab terkontrol. Seluruh aktivitas dijalankan secara sengaja oleh analis untuk menguji cakupan deteksi. Bukan insiden nyata.

ID Laporan	IR-2026-003
Judul	Simulasi Pasca-Eksploitasi — Discovery & Living-off-the-Land (5 Teknik MITRE ATT&CK)
Klasifikasi	Internal / Lab
Status	Ditutup
Tingkat Keparahan	Rendah–Sedang (satu teknik mencapai High)
Status Deteksi	TERDETEKSI SEBAGIAN — mayoritas teknik discovery tertangkap secara insidental, bukan dengan label yang tepat
Teknik MITRE ATT&CK	T1087.001, T1059.001, T1033, T1082, T1057
Sumber Serangan	Lokal (di dalam WIN-TARGET) — tidak ada IP penyerang eksternal
Aset Terdampak	DESKTOP-JR9CSOT (192.168.56.101), Windows 11 Enterprise Eval, agen Wazuh id 001
Rentang Waktu	12 Jul 2026 02:05 UTC – 13 Jul 2026 03:10 UTC (WIB = UTC+7)
Analisis	JEREMIAH MARK

Ringkasan Eksekutif

Laporan ini adalah kelanjutan langsung dari Laporan Insiden 2 (pembobolan RDP). Skenario yang diuji adalah *assume-breach*: kita berasumsi penyerang sudah berhasil masuk ke host WIN-TARGET dan kini menjalankan aktivitas pasca-eksploitasi dari dalam sistem. Tidak ada lagi lalu lintas dari IP eksternal — seluruh aktivitas berjalan secara lokal melalui utilitas bawaan Windows (*living-off-the-land*), sehingga satu-satunya sumber deteksi adalah telemetri proses dan baris perintah (Sysmon Event ID 1).

Lima teknik discovery/eksekusi yang berbeda dijalankan menggunakan kerangka Atomic Red Team. Temuan utama: **cakupan deteksi untuk aktivitas discovery masih lemah**. Dari lima teknik, hanya satu (PowerShell terenkripsi via WMI) yang memicu alert dengan tingkat keparahan High secara mandiri. Empat teknik lainnya hanya tertangkap sebagai alert tingkat Low, dan sebagian besar dilabeli sebagai "Execution" oleh ruleset bawaan — bukan "Discovery" — sehingga niat sebenarnya penyerang berpotensi terlewat oleh analis yang menyortir alert berdasarkan label MITRE.

Analisis Teknis

Kronologi Aktivitas

#	Waktu (UTC)	Teknik MITRE	Utilitas	Alert Wazuh	Level
1	12 Jul 02:05:07–09	T1087.001 — Account Discovery (Local)	net user / net localgroup (cmd)	r92052	L4

#	Waktu (UTC)	Teknik MITRE	Utilitas	Alert Wazuh	Level
2	13 Jul 00:11:37–43	T1059.001 — PowerShell	PowerShell terenkripsi via WMI	r92071	L12 (High)
3	13 Jul 01:07:25–32	T1033 — System Owner/User Discovery	whoami / quser / qwinsta	r92022	L3
4	13 Jul 02:29:28–31	T1082 — System Information Discovery	systeminfo / reg query (cmd)	r92052	L4
5	13 Jul 03:10:37–38	T1057 — Process Discovery	tasklist (cmd)	r92032 + r92052	L3 + L4

Detail Per Teknik

- T1087.001 — Account Discovery: Local Account.** Perintah `net user` dan `net localgroup` dijalankan lewat cmd.exe untuk memetakan akun dan grup lokal. Terekam pada 02:05:07–09 UTC (12 Jul), eventRecordID 22601. Memicu **r92052 level 4**, tetapi dilabeli sebagai *Execution* (T1059.003), bukan *Discovery*. Ini adalah salah-label pertama: niat sebenarnya adalah pemetaan akun, namun deteksi hanya melihat "cmd shell mencurigakan".
- T1059.001 — Command and Scripting Interpreter: PowerShell.** Perintah PowerShell yang di-encode dengan Base64 (`-EncodedCommand`) dijalankan melalui parent WmiPrvSE.exe (WMI). Terekam pada 00:11:37–43 UTC (13 Jul), PID 2536, eventRecordID 23684, SHA256 0FF6F2C9...17E8C46. Memicu **r92071 level 12 (High)** — satu-satunya teknik yang mandiri mencapai High. Yang memicu eskalasi bukan isi perintahnya (Base64 menyembunyikan isi), melainkan **pola** kombinasi PowerShell terenkripsi + induk WMI yang tidak wajar.
- T1033 — System Owner/User Discovery.** Perintah `whoami`, `quser`, dan `qwinsta` dijalankan untuk mengidentifikasi pengguna aktif. `wmic` gagal karena sudah dihapus di Windows 11 versi 24H2 (Exit 1). Terekam 01:07:25–32 UTC, qwinsta.exe eventRecordID 23756, PID 10344. Memicu **r92022 level 3** dengan label **T1033 Discovery yang benar** — satu-satunya teknik dengan pelabelan MITRE yang tepat.
- T1082 — System Information Discovery.** Perintah `systeminfo` dan `reg query` dijalankan untuk mengumpulkan detail sistem operasi dan registry. Terekam 02:29:28–31 UTC, cmd.exe eventRecordID 23877, PID 2144, SHA256 75320A51...79DED4. Memicu **r92052 level 4** — kembali dilabeli *Execution*, bukan *Discovery* (salah-label kedua).
- T1057 — Process Discovery.** Perintah `tasklist` dijalankan untuk mendaftar proses yang sedang berjalan. Terekam 03:10:37–38 UTC. Menghasilkan dua alert: tasklist.exe (eventRecordID 23961, PID 11124) memicu **r92032 level 3**, dan cmd.exe induknya (eventRecordID 23960, PID 3040, induk powershell.exe PID 9768) memicu **r92052 level 4**. Keduanya Low.

Catatan Kejujuran Keparahan

Penting untuk tidak melebih-lebihkan hasil ini. Empat dari lima teknik hanya menghasilkan alert Low (level 3–4). Aktivitas discovery ini **tidak** memicu peringatan yang menonjol di dashboard, dan tertangkap secara insidental melalui aturan "cmd shell mencurigakan" — bukan karena kita memang punya deteksi discovery yang dirancang khusus. Seorang analis L1 yang hanya melihat alert level tinggi akan **melewatkan** empat dari lima teknik ini. Inilah celah nyata yang perlu ditutup.

Indikator Teknis (IoC & Artefak)

Jenis	Nilai	Keterangan
Utilitas LOLBin	net.exe, whoami.exe, quser.exe, qwinsta.exe, systeminfo.exe, tasklist.exe, reg.exe	Utilitas bawaan Windows yang

Jenis	Nilai	Keterangan
		disalahgunakan untuk discovery
Parent mencurigakan	WmiPrvSE.exe → powershell.exe (terenkripsi)	Pola induk-anak abnormal (teknik #2)
Parent mencurigakan	powershell.exe → cmd.exe → tasklist.exe	Rantai proses abnormal (teknik #5)
SHA256	0FF6F2C94BC7E2833A5F7E16DE1622E5DBA70396F31C7D5F56381870317E8C46	Proses PowerShell teknik #2
Sumber telemetri	Sysmon Event ID 1 (Process Creation)	Satu-satunya sumber deteksi untuk aktivitas lokal ini

Rekomendasi Mitigasi

1. **Buat aturan discovery berbasis baris perintah khusus.** Deteksi rantai perintah discovery umum (`net user`, `net localgroup`, `systeminfo`, `tasklist`, `whoami`, `quser`, `qwinsta`) dan naikan levelnya dari L3–L4 menjadi $\geq$ L12 agar tidak tenggelam di antara alert Low.
2. **Perbaiki pelabelan MITRE.** Aktivitas discovery jangan dilabeli "Execution". Label yang benar memungkinkan analis memfilter dan memprioritaskan berdasarkan taktik ATT&CK yang sebenarnya.
3. **Deteksi PowerShell terenkripsi tanpa bergantung pada induk WMI.** Teknik #2 tertangkap karena induknya WMI; PowerShell terenkripsi dengan induk lain berpotensi lolos. Buat aturan yang mendeteksi pola `-EncodedCommand` secara umum.
4. **Tambahkan aturan perilaku (parent-child).** Waspadaai rantai proses abnormal seperti cmd.exe yang dijalankan oleh powershell.exe, atau powershell.exe yang dijalankan oleh WmiPrvSE.exe.
5. **Aktifkan dan periksa Sysmon Event ID 3 (koneksi jaringan).** Saat ini EID3 ditekan (blind spot), sehingga tahap discovery yang menyentuh jaringan tidak terlihat.
6. **Terapkan deteksi anomali berbasis baseline.** Bandingkan aktivitas terhadap baseline perilaku normal host, sehingga lonjakan perintah discovery beruntun dapat dikenali meski tiap perintah individual tampak jinak.